

NTRO SentinelShield

Security Assessment & Assurance Report — World Monitor Sandbox

Generated: 2026-09-28 13:42:55 UTC | Environment: ISOLATED SANDBOX

Security Assurance Score: 77.9/100
Target: Local Sandbox Automated Test
Findings Validated: 5

Executive Summary & Methodology

This assessment was executed strictly against an isolated sandbox environment. The SentinelShield Cross-Layer Correlation Engine synthesized static code analysis (SAST), API route discovery, multi-identity authorization tests, and dynamic runtime evidence into verified security controls.

Validated Security Findings

[SS-004] High-Entropy Secret Exposure: OpenAI / Anthropic API Key
Severity: CRITICAL | CVSS: 9.1 | Confidence: HIGH
Hardcoded OpenAI / Anthropic API Key detected with Shannon entropy 3.81.
Remediation: Rotate the exposed secret immediately and migrate to an environment variable.

[SS-005] High-Entropy Secret Exposure: OpenAI / Anthropic API Key
Severity: CRITICAL | CVSS: 9.1 | Confidence: HIGH
Hardcoded OpenAI / Anthropic API Key detected with Shannon entropy 3.81.
Remediation: Rotate the exposed secret immediately and migrate to an environment variable.

[SS-001] Broken Object Level Authorization (BOLA/IDOR) in Intel Dossiers API
Severity: HIGH | CVSS: 8.1 | Confidence: VALIDATED
Cross-layer validation confirmed that unprivileged User B can retrieve confidential intelligence dossiers owned by User A by supplying arbitrary resource identifiers.
Remediation: Extract `user\_id` from verified session context and enforce resource ownership checks before query execution.

[SS-003] Vulnerable Third-Party Component: axios (CVE-2024-39338)
Severity: HIGH | CVSS: 7.5 | Confidence: HIGH
Axios Server-Side Request Forgery (SSRF) vulnerability via relative URL path bypass.
Remediation: Upgrade axios to version 1.7.4.

[SS-002] Missing Content-Security-Policy (CSP) Header
Severity: MEDIUM | CVSS: 5.4 | Confidence: HIGH
The sandbox HTTP response does not specify a Content-Security-Policy header, leaving browser clients unprotected against content injection and XSS.
Remediation: Register security middleware with appropriate policy directives.